

Security+ 2.3 · Misconfiguration

Mestre CyberSec · Aula 2.3 — Misconfiguration (7:09) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Configurar errado é a falha mais comum de TODAS: senha default, porta aberta que não devia, permissão de bucket, debug mode em produção, TLS fraco, IAM permissivo. Defesa: baseline secure (CIS benchmark), CSPM automation, revisão de config antes de deploy.

💡 Highlights que a prova CompTIA cobra

- Senha default / porta aberta / permissão generosa = as failures nº1
- Defesa: baseline + automatização (CIS benchmarks, CSPM)

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'most common vulnerability is human configuration error' = misconfiguration

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Configuração incorreta (N/A)

Uma fraqueza de segurança causada por configurações inseguras ou inadequadas em sistemas, aplicações, nuvem ou rede, geralmente por erro humano ou padrões. A CompTIA enfatiza como a categoria de vulnerabilidade mais comum.

⚠ Armadilha CompTIA: Se a questão citar 'erro humano', 'padrão inseguro', 'senha default' ou 'configuração deixada como veio', marque *misconfiguration*. Não confunda com vulnerabilidade de software (bug) ou zero-day.

• Credenciais padrão (N/A)

Nomes de usuário e senhas pré-configurados por fornecedor ou dispositivo que não foram alterados. São uma misconfiguration clássica que permite acesso não autorizado trivial.

⚠ Armadilha CompTIA: Palavras como 'admin/admin', 'root/toor', 'senha de fábrica' ou 'nunca alterada' indicam *default credentials*. A correção é trocar antes da implantação e usar gerenciamento de senhas.

• Portas e serviços abertos (N/A)

Portas ou serviços de rede deixados escutando e acessíveis quando não são necessários, ampliando a superfície de ataque. Firewalls mal configurados ou serviços não intencionais frequentemente os expõem.

⚠ Armadilha CompTIA: Se a questão mencionar 'porta 3389 exposta', 'serviço desnecessário' ou 'firewall permissivo', pense em *open ports/services*. A defesa é fechar portas, desabilitar serviços e revisar regras.

• Permissões abertas (IAM)

Configurações de controle de acesso que concedem acesso mais amplo que o necessário, como buckets de armazenamento em nuvem públicos ou funções de IAM excessivamente permissivas. Isso viola o privilégio mínimo.

⚠ Armadilha CompTIA: Palavras como 'bucket público', 'S3 exposto', 'role com *', 'permissão generosa' indicam *open permissions*. A correção é aplicar *least privilege* e revisar ACLs/políticas.

• Modo debug / erros detalhados (N/A)

Configuração de desenvolvimento deixada habilitada em produção que revela stack traces, detalhes de configuração ou dados sensíveis aos usuários. Pode expor credenciais, caminhos e lógica interna.

⚠ Armadilha CompTIA: Se a questão citar 'mensagens de erro detalhadas', 'stack trace' ou 'debug ativo em produção', marque *debug mode/verbose errors*. A defesa é desabilitar debug e usar mensagens genéricas.

• TLS fraco / protocolos inseguros

Uso de protocolos obsoletos, suítes de cifra fracas ou configurações TLS inadequadas que permitem interceptação ou ataques de downgrade. Exemplos incluem SSLv3, TLS 1.0 e cifras fracas.

⚠ Armadilha CompTIA: Se a questão mencionar 'SSL', 'TLS 1.0', 'cifra fraca' ou 'protocolo legado', é configuração criptográfica insegura. A defesa é desabilitar versões antigas e usar TLS 1.2/1.3 com cifras fortes.

• Baseline seguro (CIS)

Um conjunto documentado de configurações mínimas de segurança aplicadas a sistemas, frequentemente baseado nos CIS Benchmarks. Fornece um padrão repetível para prevenir misconfigurations.

⚠ Armadilha CompTIA: Se a questão pedir a melhor defesa contra misconfiguration, procure 'secure baseline' ou 'CIS Benchmarks'. Não é apenas uma política; é configuração técnica verificável.

• Gerenciamento de postura de segurança em nuvem (CSPM)

Ferramentas automatizadas que avaliam continuamente configurações de nuvem em relação a baselines e padrões de conformidade para detectar e corrigir misconfigurations. Ajuda a identificar buckets públicos, portas abertas e IAM permissivo.

⚠ **Armadilha CompTIA:** Se a questão citar 'nuvem', 'configuração contínua', 'automação de conformidade' ou 'detectar bucket público', a resposta provável é CSPM. Diferente de CASB, que foca acesso a SaaS, e de CWPP, que protege workloads.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança examina uma sub-rede interna e encontra um appliance de gerenciamento de rede que expõe uma página de login web. O appliance é acessível de toda a VLAN de usuários, e sua conta de administrador ainda usa as credenciais impressas no guia de instalação do fornecedor. Qual má configuração é mais diretamente responsável pelo risco de acesso não autorizado?

- A) Conjuntos de cifras TLS fracos
- B) Erros detalhados de depuração
- C) Credenciais padrão
- D) Função IAM excessivamente permissiva

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa implanta um novo servidor de e-commerce. Uma revisão de segurança em nuvem mostra que o serviço MySQL na TCP 3306 está acessível a partir de 0.0.0.0/0 porque o security group permite todo o tráfego de entrada. Qual má configuração deve ser corrigida primeiro?

- A) Credenciais padrão
- B) Portas e serviços abertos
- C) Modo de depuração habilitado
- D) Política IAM permissiva

QUESTÃO 3 · CENÁRIO DE EXAME

Um engenheiro de nuvem cria um bucket de armazenamento de objetos para relatórios financeiros. Um testador de penetração depois baixa os relatórios sem autenticação e relata que a política do bucket concede s3:GetObject para todos. Qual categoria de má configuração isso representa?

- A) Protocolos TLS fracos
- B) Sistema operacional sem patch
- C) Modo de depuração habilitado
- D) Permissões abertas

QUESTÃO 4 · CENÁRIO DE EXAME

Usuários de um aplicativo interno relatam que, ao enviar entrada inválida, a página web retorna um stack trace completo, incluindo strings de conexão de banco de dados e caminhos de arquivos internos. Qual problema de configuração a equipe de segurança deve corrigir?

- A) Credenciais administrativas padrão
- B) Porta do banco de dados aberta para a internet
- C) Modo de depuração ou relatório de erros detalhados habilitado
- D) Conjuntos de cifras TLS fracos

QUESTÃO 5 · CENÁRIO DE EXAME

Um serviço web legado está configurado para aceitar TLS 1.0 e RC4 porque o fornecedor não atualizou a aplicação. Um auditor sinaliza isso como achado. Qual remediação aborda melhor a má configuração?

- A) Habilitar log detalhado para todos os handshakes TLS
- B) Desabilitar protocolos e conjuntos de cifras fracos, depois exigir TLS 1.2 ou superior
- C) Rotacionar a senha da conta de serviço a cada 90 dias
- D) Mover o serviço para uma sub-rede pública com um WAF

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa está padronizando novas instalações de servidores Linux. Atualmente, administradores instalam uma imagem genérica, deixam vários serviços desnecessários habilitados e usam configurações de senha inconsistentes. A gerência quer uma lista de verificação de hardening repetível e reconhecida pelo setor antes da implantação. Qual abordagem deve ser usada?

- A) Habilitar um firewall de aplicação web em modo de monitoramento
- B) Configurar uma regra de correlação no SIEM para falhas de login
- C) Implantar detecção e resposta de endpoint em todos os servidores
- D) Aplicar uma baseline segura, como CIS Benchmarks

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa multinacional tem centenas de contas em nuvem em dois provedores. A equipe de segurança precisa de visibilidade contínua e automatizada sobre armazenamento exposto publicamente, security groups irrestritos e volumes não criptografados, com alertas quando novos recursos violarem políticas. Qual solução se encaixa melhor nesse requisito?

- A) Sistema de prevenção de intrusão baseado em host
- B) Gerenciamento de Postura de Segurança em Nuvem (CSPM)
- C) Firewall de aplicação web
- D) Monitoramento de integridade de arquivos

QUESTÃO 8 · CENÁRIO DE EXAME

Uma equipe DevOps usa Terraform para provisionar infraestrutura na AWS. A segurança quer detectar buckets S3 públicos e security groups excessivamente abertos antes que a infraestrutura seja criada, sem esperar por uma varredura pós-implantação. O que deve ser integrado ao pipeline CI/CD?

- A) Proteção de carga de trabalho em nuvem em tempo de execução
- B) Gerenciamento de informações e eventos de segurança
- C) Detecção e resposta de endpoint
- D) Varredura de segurança de Infrastructure as Code (IaC) com verificações de política

QUESTÃO 9 · CENÁRIO DE EXAME

Uma função serverless é executada em uma conta de nuvem. Sua função de execução permite Action: "*" em Resource: "*" porque um desenvolvedor usou um template de início rápido e nunca o alterou. Qual má configuração deve ser remediada?

- A) Versão fraca de TLS
- B) Credenciais padrão da aplicação
- C) Permissões IAM excessivamente permissivas
- D) Bucket de armazenamento de objetos público

QUESTÃO 10 · CENÁRIO DE EXAME

Uma VM em nuvem executa um armazenamento de dados em memória na TCP 6379. O security group permite tráfego de entrada de qualquer IP, e o serviço não tem autenticação habilitada. Atacantes se conectam e gravam entradas não autorizadas. Qual má configuração é a causa principal?

- A) Mensagens detalhadas de depuração
- B) Porta de serviço aberta sem autenticação
- C) Conta padrão do sistema operacional
- D) Conjunto de cifras fraco no servidor web

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Credenciais padrão

O risco é causado por credenciais de administrador fornecidas pelo fabricante e não alteradas. Credenciais padrão são uma má configuração comum porque atacantes podem consultar nomes de usuário e senhas documentados. Os outros problemas podem ser riscos, mas não são a causa direta descrita aqui.

Questão 2: Alternativa B — Portas e serviços abertos

O serviço de banco de dados está exposto à internet por uma regra de security group ampla demais, o que é uma má configuração de portas/serviços abertos. A correção imediata é restringir a regra às origens necessárias e remover a exposição desnecessária. Credenciais padrão, modo de depuração e políticas IAM são categorias separadas de má configuração.

Questão 3: Alternativa D — Permissões abertas

A política do bucket permite leitura pública não autenticada, o que é uma má configuração de permissões abertas. Permissões de armazenamento em nuvem devem seguir privilégio mínimo e ser revisadas continuamente. TLS fraco, patch e modo de depuração são problemas diferentes.

Questão 4: Alternativa C — Modo de depuração ou relatório de erros detalhados habilitado

Stack traces detalhados e strings de conexão nas respostas indicam que o modo de depuração ou relatório de erros detalhados está habilitado em produção. Isso vaza detalhes sensíveis de implementação para atacantes. A correção é desabilitar a saída de depuração e retornar mensagens de erro genéricas.

Questão 5: Alternativa B — Desabilitar protocolos e conjuntos de cifras fracos, depois exigir TLS 1.2 ou superior

TLS 1.0 e RC4 são obsoletos e fracos. A remediação correta é desabilitá-los e exigir versões modernas de TLS e conjuntos de cifras fortes. Logs, rotação de senha e colocação de WAF não corrigem configuração fraca de TLS.

Questão 6: Alternativa D — Aplicar uma baseline segura, como CIS Benchmarks

Uma baseline segura como CIS Benchmarks fornece um conjunto repetível e reconhecido pelo setor de configurações de hardening para sistemas operacionais e serviços. Ela aborda serviços desnecessários, política de senha e outros itens de configuração antes da implantação. WAF, SIEM e EDR são valiosos, mas não substituem a configuração de baseline segura.

Questão 7: Alternativa B — Gerenciamento de Postura de Segurança em Nuvem (CSPM)

Ferramentas CSPM avaliam continuamente configurações de nuvem em relação a políticas e benchmarks, detectando problemas como armazenamento público, security groups abertos e criptografia ausente. HIPS, WAF e FIM abordam camadas diferentes e não fornecem gestão ampla de postura de configuração multicloud.

Questão 8: Alternativa D — Varredura de segurança de Infrastructure as Code (IaC) com verificações de política

A varredura de IaC analisa templates como Terraform antes da implantação e pode falhar o pipeline quando recursos violam políticas de segurança. Isso desloca a detecção de más configurações para a esquerda, antes que os recursos sejam criados. Runtime, SIEM e EDR não são controles de IaC pré-implantação.

Questão 9: Alternativa C — Permissões IAM excessivamente permissivas

A função concede permissões administrativas totais à função, violando o privilégio mínimo. Políticas IAM excessivamente permissivas são uma má configuração comum em nuvem. A correção é limitar ações e recursos apenas ao que a função precisa. TLS fraco, credenciais padrão e buckets públicos são problemas distintos.

Questão 10: Alternativa B — Porta de serviço aberta sem autenticação

O armazenamento de dados está exposto à internet em uma porta aberta e sem autenticação, o que é uma má configuração de portas/serviços abertos. A correção é restringir o acesso de rede e habilitar autenticação. Mensagens de depuração, contas padrão do sistema operacional e cifras do servidor web não são a causa principal descrita.